

# KBID: Kerberos Bracelet Identification

Joseph Carrigan, Paul Martin, and Michael Rushanan

Johns Hopkins University {joseph.carrigan,pmartin,mrushan1}@jhu.edu

Something the user knows. Something the user has.

**Abstract** The most common method for a user to gain access to a system, service, or resource is to provide a secret, or password, that verifies her identity and thus authenticates her. Password authentication is considered strong only when it is composed of some combination of letters, numbers, and special characters, or when it is used as a factor in a multi-factor authentication. Unfortunately, many authentication systems do not enforce strong passwords due to a number of limitations, such as the time taken to enter complex passwords and the limitation of precise recall (i.e., the ability of human cognition to recall complex information). We present an authentication system that addresses these limitations by prompting the user for her credentials once, then storing a Kerberos ticket in a wearable device we call Kerberos-based Identity bracelet (KBID). Specifically, KBID is an embedded device that uses body coupled communication (BCC) to transmit Kerberos tickets to and from an authentication module that the authenticating user is in physical contact with. Our authentication system achieves usable and continuous authentication with complex passwords.

**Keywords:** authentication, kerberos, wearables, passwords

## 1 Introduction

The use of modern computer systems almost always requires that a user somehow prove their identity to the system. The process of proving a user's identity is called authentication. There are different ways that authentication can be achieved including public key authentication, biometrics, and passwords. Password based authentication remains the most widely used option for authentication because it is easy for developers to implement and easy for users to understand.

However passwords have a human factor weakness in that users choose passwords that are too simplistic and easily guessed. Thus, administrators encourage or enforce users to select more complex and longer passwords. More complex and longer passwords decrease user satisfaction because entering the passwords is perceived as difficult. This difficulty is compounded when the user enters a password incorrectly and has to re-enter it. Additionally, the likelihood of entering a password incorrectly only increases with password complexity and length as does the time to enter and re-enter it. The difficulty of entering a complex password rises to an unacceptable level very quickly in a medical or clinical setting, particularly when patient needs are urgent.

In this paper we describe a system for user authentication that requires the user to enter a password as infrequently as one time per work shift. Authentication information is stored in a wearable device, specifically a bracelet. The authentication information is transmitted using the user's body as the communication medium in a process called Body Coupled Communication (BCC). Our goal is to provide access to a user in less than one second for users who have provided valid credentials once. The hope is to reduce the resistance to strong password requirements by removing the vast majority events where the user is asked to enter a password. To put it simply, users will be more willing to use a strong password if they only have to enter it once a day as opposed to being prompted to enter the password each time they use a computer system.

To use the system, the user will don a wearable device. Currently we envision this device as a bracelet. The user will approach a host computer equipped with a special hardware to communicate with the bracelet. We will refer to this hardware as an authentication module. The user will touch a sensor on the authentication module and the authentication module will communicate over the user's skin and determine that the user is not authenticated. The authentication module will then communicate with a software client on the host computer and the software will prompt the user to log in. The user will provide a username and password that will be validated with the back end authentication server. If the user's credentials are valid, the server will provide authentication information to the client. The client will instruct the user to touch the sensor on the authentication module again. When the user touches the authentication module the client will send the authentication information to the authentication module which will in turn pass it over the user's skin to the bracelet where it will be stored.

The next time the user wishes to authenticate to a host computer equipped with this system, the user will touch the authentication module. The authentication module will ask the bracelet for the authentication information and the bracelet will provide it. The authentication module will then send the authentication information to the client on the host computer. The client will verify the validity of the authentication information with the authentication server. If the authentication information is valid the client will unlock the host computer. It is these subsequent authentication events that should take less than one second.

If the user removes the bracelet, the bracelet has a means of detecting its removal. When it detects its removal the bracelet will delete the authentication information it contains. In order to continue using the system, the user must put the bracelet back on and re-authenticate using a username and a password.

It is conceivable that users of computer systems in a clinical setting may not be able to use a keyboard and mouse due to sanitation concerns. An additional benefit of this system is that clinicians could authenticate by making contact between the sensor and another part of their arm, such as the elbow, without compromising the sanitization of their hands.

While we have focused on developing an authentication system for the medical community, there is nothing in the authentication system that prevents it from

being used in other areas. We anticipate that the financial sector may find our system interesting.

At their developer conference in August 2015, Intel announced a wearable authentication solution. The Intel solution has a very similar workflow and seems to achieve similar results. However the Intel solution uses Bluetooth Low Energy (BLE). We speculate that the Intel solution may be vulnerable to a range extending attack. In the speculative attack, an attacker intercepts the BLE signal from the user's wearable device and the computer to which they are authenticated. The attacker then rebroadcasts the BLE traffic over a longer distance, possibly by translating the traffic to another section of the RF spectrum during the retransmission process. No authentication or pairing is required since all the attacker is doing is receiving and then rebroadcasting BLE traffic from previously paired and authenticated equipment. Our system reduces or eliminates this type of attack by requiring that the user be in physical contact with the authentication device to transmit authentication information.

It is important to note what this system is not. This system is not a two factor authentication solution. It is conceivable that this system could include a two factor authentication component but the bracelet should not be confused as the provider of additional authentication information outside of what it is instructed to hold. There is no Biometric component to this system. Neither the bracelet nor the authentication module measure or store any information about the user's physical state. In this system the user's body is simply the medium across which the authentication information is communicated. This system is not a complete authentication system. It is meant to be an enhancement to the user experience and to encourage the use of strong passwords by eliminating the need to repeatedly entering them. As such there will be no discussion in the paper about access control, password hashing, and much of the intricacies of the of the authentication process. For this research Kerberos was used as the authentication provider but it is important to note that this system will support the use of any authentication provider that requires the use of stored tokens or tickets. It could also be enhanced to provide its own tokens or tickets, though that is beyond the scope of the planned research on this project.

## 2 Background

The original concept for this system came from "ZEBRA: Zero-Effort Bilateral Recurring Authentication" by Shrirang Mare, Andres Molina-Markham, Cory Cornelius, Ronald Peterson and David Kotz at Dartmouth College where they describe ZEBRA thusly:

"In ZEBRA, a user wears a bracelet (with a built-in accelerometer, gyroscope, and radio) on her dominant wrist. When the user interacts with a computer terminal, the bracelet records the wrist movement, processes it, and sends it to the terminal. The terminal compares the wrist movement with the inputs it receives from the user (via keyboard and mouse), and confirms the continued presence of the user only if they correlate. Because the bracelet is on the same

hand that provides inputs to the terminal, the accelerometer and gyroscope data and input events received by the terminal should correlate because their source is the same — the user's hand movement."

At the time, ZEBRA was only envisioned as a method to de-authenticate a user from a computer system and did not include a way to initially authenticate the user to the system. Assuming that the user has already accepted wearing a device that will effectively de-authenticate them, adding functionality to rapidly authenticate them only increases the usefulness of the system.

We wanted to avoid using radio frequency (RF) emissions due to the fact that it relies on the underlying framework of communication being secure. If a security flaw is discovered in an RF communication framework, e.g. Bluetooth LE, then the systems as it exists would be vulnerable to the flaw. Further since the purpose of this system is near instant authentication, there is no need to alter or even monitor the information that is exchanged between the computer system and a wearable device. An attacker would only need to extend the range of the wireless communication in order to gain access to the computer system.

We considered adding contacts to the wearable device. This would allow the direct exchange of information over a closed circuit without the ability to use and extended range attack. However, the human factors issues became clear when we considered the design. Thus we were left with BCC.

In 2012, Sang-Yoon Chang, Yih-Chun Hu, Hans Anderson, Ting Fu (University of Illinois at Urbana-Champaign), and Evelyn Y. L. Huang (University of Illinois at Chicago) published a paper (Link: <https://www.usenix.org/conference/healthsec12/workshop-program/presentation/chang>) on key exchanges over a body area network. By applying a very small voltage to the tissue of a dead mouse, they were able to communicate at a rate of 5Hz or 5 bits per second. This data rate would not be an acceptable data rate for our work since we would need to communicate authentication data of 256 bits at a minimum. At the rates Chang et al achieved, it would take nearly a minute to transmit 256 bits.

We also wanted to be sure that the authentication information was non-transferable once the bracelet was holding it. Thus we incorporated a feature in the design that would clear out the authentication information once it detected that the bracelet was removed.

Finally we wanted to provide an authentication model that was useful as a real world example. Thus we incorporated a Kerberos server as the source of authentication.

### 3 Related Work

Related work can be divided into two key areas: authentication and deauthentication. Authentication-based research looks at using wristbands or other wearables to help authenticate a user to a computing resource. Deauthentication-based research focuses on wearables that do the opposite—helping to deauthenticate a user from a computer resource when the user is done using the resource. Some wearables are able to both authenticate users to and deauthenticate users from

computing resources [1] while other wearables can only be used for authentication or for deauthentication [2].

### 3.1 Authentication

There have been several previous attempts at developing wearable-authentication technology. Some of these attempts have taken drastically different approaches than kbid while others share some similarities. However, none of the existing technology has considered using skin conductance as the transfer vehicle for the authentication token in order to provide robustness against repeater attacks.

**Bionym Nymi** The Bionym Nymi [3] is an authentication wristband that broadcasts a digitally signed authentication signal derived from a user's heartbeat to nearby devices using Bluetooth Low Energy. "The Nymi's ECG recognition algorithms observe the shape of the ECG waveform, extracting unique and consistent features that are a result of a user's physiology. The Nymi is robust against a wide variety of health issues." [3].

**Intel Authentication Bracelet Prototype** Intel, in partnership with Fossil, has announced a prototype for an authentication bracelet based on its Curie platform [4]. The bracelet is designed to automatically unlock a device when a given user is nearby. When the bracelet is first put on, the user must log in to a bracelet-enabled device with a standard password. However, subsequent logins to bracelet-enabled devices do not require a password and the bracelet will continue to broadcast an authentication token until the bracelet has been taken off, thus breaking a circuit and causing the device's volatile storage to lose the authentication credential. The bracelet uses Bluetooth Low Energy to broadcast its credential to nearby bracelet-enabled devices.

**Limitations of Existing Work** Existing authentication wearables use wireless communication technology (typically Bluetooth LE) to broadcast their authentication credentials. Thus the devices are likely vulnerable to ghost-and-leech attacks. Ghost-and-leech attacks occur when an attacker uses a more powerful radio transmitter than the transmitter found on a wireless device in order to capture and rebroadcast the wireless signal.

In our context, an attacker could capture and rebroadcast the authentication signal off of an authentication wearable and thus could log in to a computer terminal even when an authorized user is not near the terminal. For example, in a hospital, a doctor might wear an authentication bracelet which continuously broadcasts a changing login credential using Bluetooth Low Energy. An attacker might place a receiver next to a target doctor's office. The receiver could then capture the signal and send it to a portable rebroadcaster which the attacker could use to unlock a computer terminal far from the doctor's office. Due to the wireless nature of these types of authentication wearables, these types of attacks can be extremely difficult to protect against.

### 3.2 Deauthentication

There are numerous wearables that are able to successfully deauthenticate a user when the physical connection between the wearable and the computer is broken [1]. Most of these techniques form a circuit that can be physically broken when the wearable is removed [1] but some more advanced techniques such as Apple's "Wrist Detect" [1] can determine if a wearable is in constant contact with skin.

**ZEBRA: Zero-Effort Bilateral Recurring Authentication** ZEBRA [1] was developed to solve a very different problem than the authentication bracelets described above. Instead of authenticating a user to a computer terminal, ZEBRA is focused on detecting when a user is done using the computer terminal and deauthenticating the user from the terminal even if the user forgets to do so. ZEBRA is prototyped as a bracelet containing an accelerometer and a variety of sensors. A user puts on the bracelet and begins using a computer terminal as he or she normally would. ZEBRA dynamically builds a profile of the user's hand movements in a short amount of time and then enforces this profile for the duration of the user's computing session by comparing the hand movements observed with the wrist band to data captured from keyboard and mouse movements.

## 4 Threat Model

We describe KBID as an authentication mechanism that requires a wearable device that transmits short-range authentication data via BCC. We recognize confidentiality, integrity, and availability as security goals specific to KBID. Specifically, data stored on the device and transmitted to the authentication module should be kept secret from and not modifiable by unauthorized entities, and the data should be accessible to both bracelet and authentication module. We omit the privacy of the authenticating user because the system must validate her access to the system or resource.

Adversaries are typically distinguished based on their goals, capabilities, and relation to a system (i.e., KBID). We define the following adversarial classification criteria for KBID: active adversaries that are able to read, modify, and inject communication between the device and authentication module, and passive adversaries that can eavesdrop on the communication; internal entities that have legitimate access to the device, and external entities that do not; single or coordinated group entities, and; sophisticated adversaries with specialized equipment (e.g., high-gain directional antenna or unauthorized authentication module), and unsophisticated adversaries with common equipment.

The KBID device or authentication module may both be used as attack surfaces. For example, an adversary may disrupt KBID authentication by physically damaging the wearable device or authenticator module. We classify this and other KBID security threats into the following categories: BCC threats, whereby the adversary is able to passively eavesdrop on communication, or actively jam, replay, modify, forge, or drop communication; hardware threats, whereby the

adversary is able to induce incorrect outputs from a valid device, and; software threats, whereby the adversary is able to alter the logic of KBID's device, authentication module, or client software through software vulnerabilities.

## 5 Design

Here we describe in detail the design and implementation of the KBID system. First we discuss the high level design where we explain the four major components of the system. Next we will discuss the interface designs and the communication protocols between the major components. Then we will discuss the system workflow. Finally we will discuss the hardware design of two of the components.

### 5.1 High Level Design

The system is composed of four main parts: a bracelet, an authentication module, an authentication client, and a Kerberos authentication server. The bracelet is a wearable device that fastened to the user's wrist. The bracelet makes contact with the user's skin and applies a signal directly to the user's skin. The authentication module has a sensor with a button under it. When the user touches the sensor and depresses the button, the authentication module initiates communication with the bracelet. The authentication module is attached via RS-232 serial to the computer system to which the user wants to authenticate. The workstation is the host for an authentication client. The client monitors the serial connection for data and when necessary, opens a connection to the Kerberos server for authentication. Finally, the Kerberos server is a default installation and uses the default implementation of the authentication protocol.

### 5.2 Interface and Communication

The KBID system includes three interfaces. There is the interface between the bracelet and the authentication module that takes place over the user's skin. There is the interface between the authentication module and the authentication client that takes place over RS-232 serial. Finally, there is an interface between the authentication client and the Kerberos server. Since the communication between a client and a Kerberos server is well documented, we will not discuss it in this paper.

**Bracelet to Authentication Module** The communication protocol between the bracelet and the authentication module is a very lightweight protocol. The messages that the bracelet sends to the authentication modules are called "statuses." The messages that the authentication module sends to the bracelet are called "commands." All messages are a series of bytes that are transmitted across the user's skin. A status message had the following structure: [Status ID] [Device ID] [Token Size (in bytes)] [Token]. These fields are delimited by length according to the following table:

|            |                  |
|------------|------------------|
| Status ID  | 1 Byte           |
| Device ID  | 4 Bytes          |
| Token Size | 2 Bytes          |
| Token      | 0 to 65535 bytes |

The Status ID will be sent as 0x01 if the bracelet is not authenticated and 0x02 if the bracelet is authenticated. The Bracelet ID will always be transmitted when the bracelet sends a status. It is a unique identifier for the specific bracelet. If the bracelet is not authenticated the Token Size field will be set to 0x00 and the token will be of length 0. If the bracelet is authenticated then the Token Size field will reflect the length of the token that follows. Naturally, the token data will be of a length defined by the token size field.

A command message has the following structure: [Command ID] [Device ID] [Payload Size (in bytes)] [Payload]. These fields are delimited by length according to the following table:

|              |                  |
|--------------|------------------|
| Command ID   | 1 byte           |
| Device ID    | 4 bytes long     |
| Payload Size | 2 Bytes          |
| Payload      | 0 to 65535 bytes |

The authentication module will send three commands. The first command is a "Get Status" command. This is the only command to which the bracelet will respond. The Command ID is 0x01, the device ID is set to a special value of 0xFFFFFFFF which the bracelet will regard as a broadcast ID, and the payload size is 0x0000. The payload is of length 0. When the bracelet receives a "Get Status" message it responds with a status message.

The second command is a "Set Token" command. The Command ID is 0x02. The Device ID is set to the ID of the bracelet, and the payload size will be set to the length of the token to be stored. The token will be appended after the message. When the bracelet receives a "Set Token" command it will store the payload in memory and set its status to "Authenticated."

Finally, the authentication module can send a "De-authenticate" command. The Command ID is set to 0x03 and the Device ID is set to the device of the bracelet to be authenticated. The Payload Size is 0x00 and the payload is of length 0. When the bracelet receives this message it will clear any token it has, byte by byte and set its status to "Un-Authenticated."

**Authentication Module to Authentication Client** The authentication module and the authentication client communicate status and command messages as well. The authentication module can send three statuses to the authentication client. First is the "Un-authenticated Bracelet" message. This message is sent to the authentication client when the authentication module receives an "un-authenticated" status from a bracelet.

Next the authentication module can send an "Authenticated Bracelet" status to the authentication client. It will send this status when the bracelet sends a status of "Authenticated" and the "Authenticated Bracelet" Status will contain the ticket information that was in the token section of the bracelet's message.

Finally, the authentication module can send a "Ticket Written" status to the authentication client. This is a message that lets the client know that the ticket information has been successfully written to the bracelet.

The authentication client sends two commands to the authentication module. First the "Write Ticket" command. This instructs the authentication module to pass the ticket included in the command to the bracelet with a "Set Token" command. The authentication client can also send a "De-authenticate Bracelet" command. This instructs the authentication module to issue a "De-Authenticate" command to the bracelet.

### 5.3 System Workflow

The System workflow can be described simply in two use cases. For the sake of brevity this description of these use cases does not include any error handling. The first use case is described in Figure 1. In this use case the user is wearing a bracelet but the bracelet does not yet contain any authentication information. The user touches the sensor on the authentication module, the authentication module sees that the user's bracelet is not authenticated. The authentication module tells the authentication client that the user is not authenticated and the client then prompts the user for their username and password. The client verifies this information with the Kerberos server. Then instructs the user to touch the sensor on the authentication module again. The client then instructs the authentication module to write the ticket to the bracelet. Once the ticket has been written, the client unlocks the workstation. The message exchange for this use case can be seen in Figure 2.



**Figure 1.** Un-Authenticated Use Case

The second use case outlines what happens when the user has a proper token stored in their bracelet. It is described in Figure 3. It seems very simple from the user's point of view. The user touches the sensor on the authentication module and the workstation unlocks. The process behind the scenes is also much simpler. The module asks for a status, and the bracelet provides it with the token it has stored. The module passes this information along to the clients which interoperates the token as a Kerberos ticket. The client verifies the ticket with the Kerberos server and unlocks the workstation. The message exchange for this use case is presented in Figure 4.

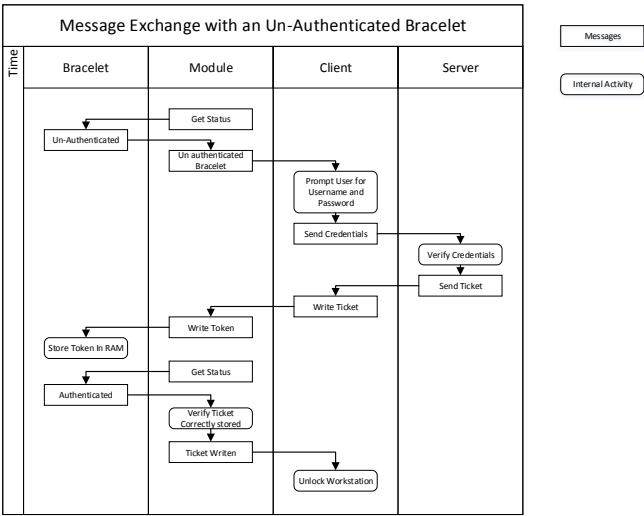


Figure 2. Un-Authenticated Message Exchange

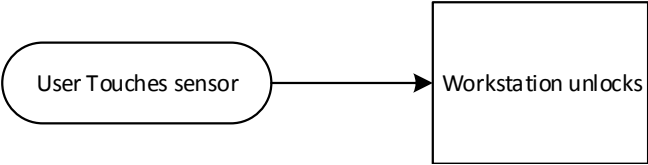


Figure 3. Authenticated Use Case

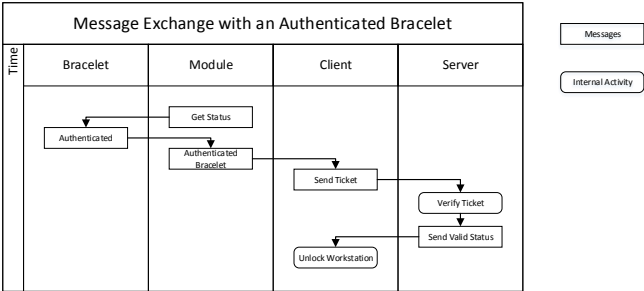


Figure 4. Authenticated Message Exchange

## 6 Experiments and Results

### 6.1 Prototype

The development of a prototype is in well underway. The hardware prototypes for the bracelet and the authentication module are based on the Atmel ATmega328 microcontroller operating at 20 MHz and an LM358AN Amplifier which has a . Both the bracelet and the authentication module have copper pads that make contact with the user's skin. The signal from the skin is fed into the amplifier and the signal to the skin is driven by setting a pin on the microcontroller. We also build a resistive analogue to represent the resistance from a user's wrist to their finger tip. The prototype for the authentication client has been written in Python.

### 6.2 Results

Initial results are encouraging. We are able to send commands from the authentication module to the bracelet. The bracelet can correctly interpret those commands and it responds when provided a "get status" command. The time elapsed for a get status command and a status message with a 256 byte token is approximately 500 milliseconds.

### 6.3 Hurdles

We encountered two major hurdles during the development of the prototype. First, in order to successfully send a signal the bracelet and the authentication module must have a common reference for voltage. Second, while we have been able to get the signal to transmit from the authentication module to the bracelet, we have not been able to get the signal to travel in the opposite direction and arrive in a way that the signal can be interpreted by the authentication module. To solve both of these issues, we plan on changing the method by which the signal is transmitted over the user's skin to capacitive coupling.

## 7 Future Work

Future work will focus on improving the system. We plan to implement the system using a microcontroller that can store larger keys. The Atmel ATmega328 that the bracelet and authentication module currently use only have 2 kilobytes of ram. This limits the size of the key that is stored in ram to little more than 1 kilobyte once all the memory various functions of the devices is accounted for. This is not sufficient space to store authentication information in real world environments. We also plan on hardening the system against the threat models we are aware of. For example we may add the storage of pre-shared keys to protect against replay attacks and "The Door Knob" attack by allowing encrypted communication and challenge response protocols. In the long term may continue the development

of the system model to include a system where passwords are not required at all. A user would check in with a security technician who would personally and physically validate the user's identity then provide the user with a bracelet and assist authenticate the user without the user entering any information into a computer. Finally we plan on submitting the system for internal review to get it clear for testing on human subjects.

All links were last followed on October 5, 2014.